

IBM SKILLATHON 2026

Health Journey

A privacy-first AI health companion — powered by IBM Bob

Your medical life is scattered across folders, portals and WhatsApp forwards. Health Journey brings it into one place — and puts an assistant on top of it that explains your record in plain language, and never guesses.

TEAM NOVATRA

New Horizon College of Engineering

Mantripragada Ramaa Gayatri · Allu Uma Eashanvi · Krupa L P · Madhumitha K

Nobody is holding the whole picture

01

It is scattered by design

Lab reports sit with the diagnostic chain. Prescriptions sit on paper. Scans sit in a hospital portal you log into once. No single place holds the record.

02

It is remembered by a person

Follow-ups, annual screens and vaccine boosters live in somebody's head. When that person is busy, unwell, or caring for a parent as well, things are simply missed.

03

It is unreadable when it matters

A lab report is thirty markers and a reference range. Patients cannot read it, and a seven-minute consultation is not enough time to explain it.

The obvious answers each miss something



Hospital portals

Accurate, but siloed. One portal per hospital, and none of them talk to each other. You cannot see your journey, only one provider's slice of it.



Consumer health apps

Good at steps and sleep. They track what a wearable can measure, not what a clinician wrote — and they upload everything to a server.



A general AI chatbot

Fluent and confident, with no access to your record — so it generalises, or invents. A confident wrong number is the failure mode that matters here.

The gap

Nothing owns the whole journey, explains it in plain language, and keeps it on your own device.

One record. One assistant. On your device.

1

Everything in one timeline

Upload a report and it is catalogued and placed on your health timeline in a single step — no forms, no filing.

2

IBM Bob explains it

An assistant that reads your actual record and answers in everyday language — medications, appointments, what to ask your doctor.

3

It never leaves your machine

The record is stored locally. No account, no server, no tracking. Privacy by architecture, not by policy.

4

It tells you what it cannot do

Ask for a lab value it has not read and it says so, plainly, instead of guessing a number at you.

This is running software, not a mockup



● Live data, end to end

Every number on that screen is served by the Flask API from a local record store. Nothing is hard-coded.

● It writes back

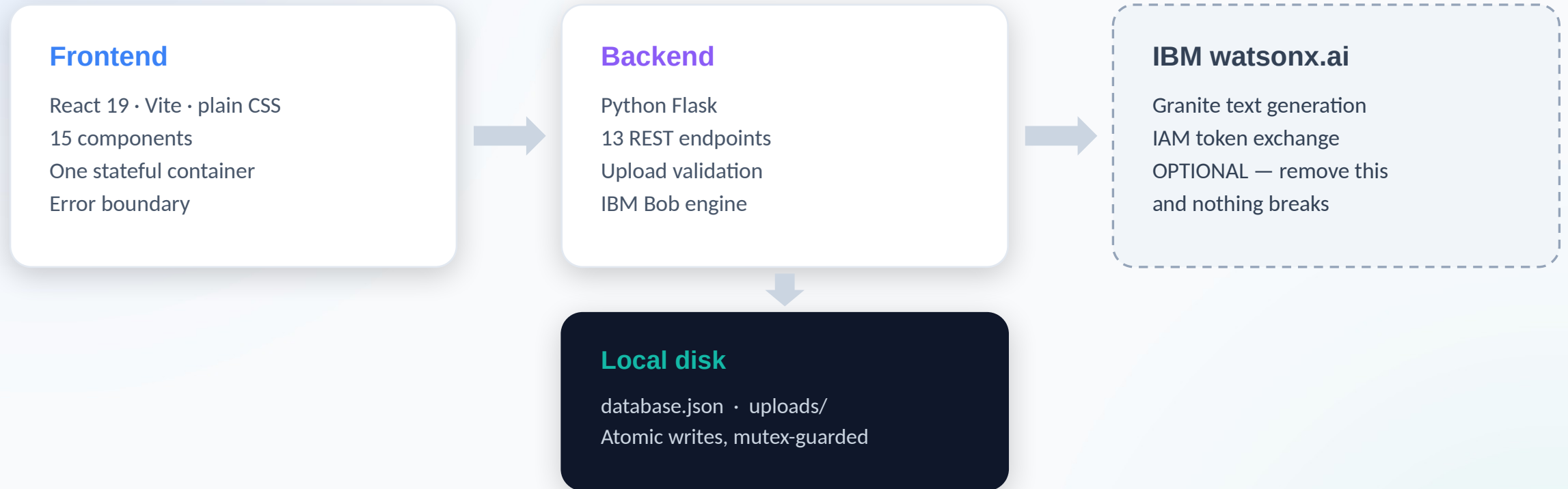
Tick a medication or a focus task and it persists. Restart the server and it is still ticked.

● Built to a design system

15 modular React components, plain CSS, one stateful container, wrapped in an error boundary.

React 19 + Vite · Flask backend · 13 REST endpoints · local JSON record store

Built so the AI can fail without the product failing



Design principle: the application organises health information. Clinical decisions remain with qualified medical professionals.

A two-tier engine, so the assistant is never dead

1

Tier 1 — IBM watsonx.ai

Granite instruction model, called with the record serialised into the prompt. Activates automatically when credentials are present. IAM token cached until expiry.

Used when configured and reachable

2

Tier 2 — grounded local engine

Reads the record and computes the answer. No canned strings — every figure is derived from live state at request time. Runs with zero network.

Automatic fallback — always available

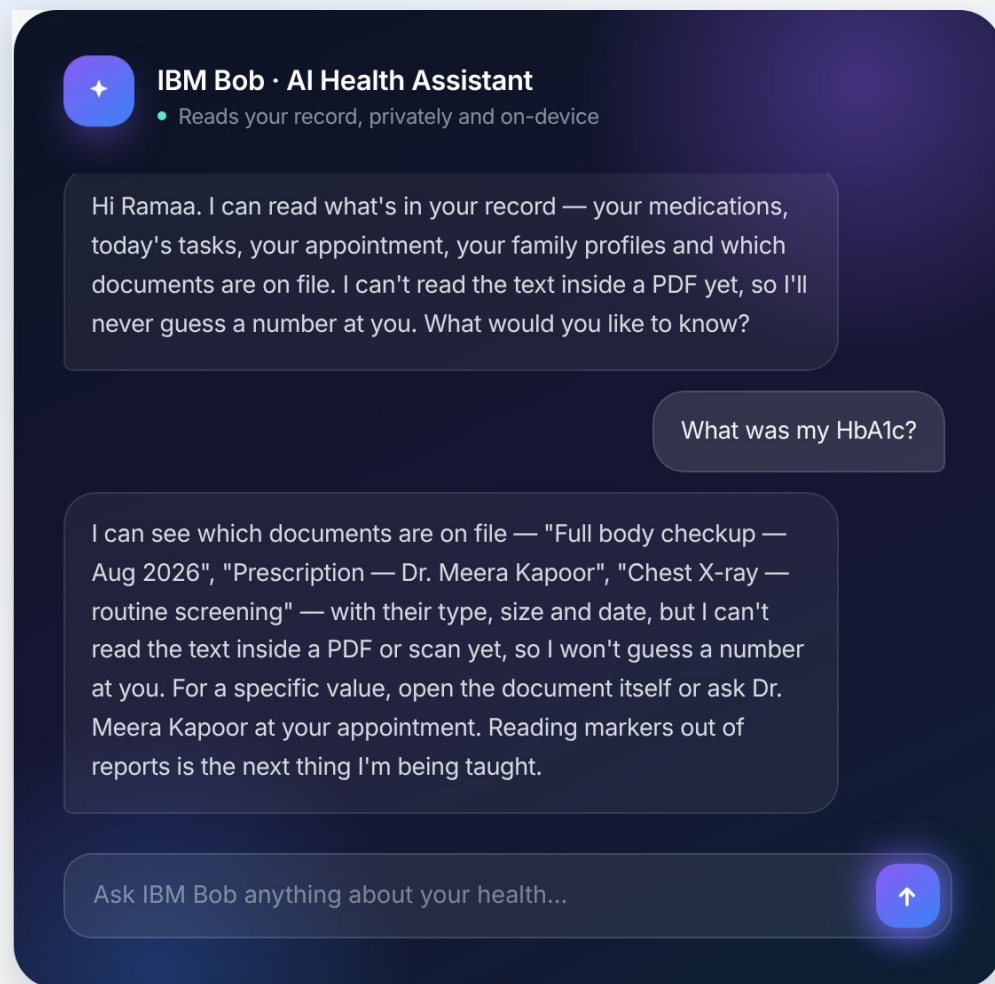
Proof that Tier 2 is real, not a stub

Tick a medication. Ask the same question again. The answer changes — because it is computed from the record, not retrieved from a script.

80

tests across
9 intent branches

The most important thing it does is refuse



It knows the limit of its own knowledge

Documents are catalogued by name, type, size and date. The text inside a PDF is not read — and IBM Bob says so rather than producing a plausible number.



The rule is enforced twice

Rule 3a constrains the watsonx model, and a dedicated branch enforces the same behaviour in the offline engine. Both tiers answer identically.



Never diagnoses, never prescribes

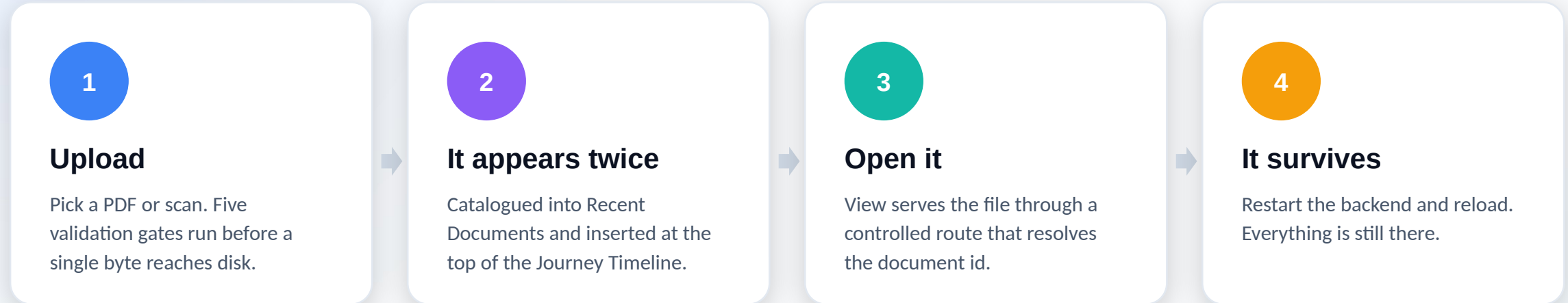
Both engines defer clinical judgement to the named clinician, and neither will advise starting, stopping or changing a medication.



Every answer declares its source

Each response reports which engine spoke and how many records it was grounded on. The degraded mode is published, not hidden.

Upload once — it lands everywhere it should



The persistence proof

Upload a report. Stop the server with Ctrl+C. Start it again. Reload the page.

The document, the timeline entry, the medications you ticked and the tasks you completed are all still there — written to disk atomically on every change, not held in memory.

Recent Documents

Full body checkup — Aug 2026 2 days ago · 1.8 MB · Apollo	View	Delete
Prescription — Dr. Meera Kapoor Jun 28 · 420 KB · 3 medications	View	Delete
Chest X-ray — routine screening May 11 · 6.2 MB · Fortis Imaging	View	Delete
Insurance policy — renewal 2026 Apr 02 · 980 KB · HDFC Ergo	View	Delete

Five gates before a byte touches the disk

1

Extension allowlist

PDF, PNG, JPEG only

2

Size limit

20 MB cap

3

Magic-byte sniff

Renamed .exe rejected

4

Content vs extension

Mismatch refused

5

Dimension check

Blocks image bombs

Opaque storage

Files are stored under generated UUIDs, never the name the user supplied.

Prompt-injection defence

Document names are fenced as untrusted data before they reach the model.

Loopback only

The server binds to 127.0.0.1 by default — not reachable from the network.

Each gate was verified by building the attack and firing it at a running server — a renamed executable, an HTML file with a script tag, a 50000 × 50000 pixel decompression bomb. All rejected. All three real formats accepted.

Nine review sessions, all in the repository

9

review sessions,
each one documented

32

findings raised
across the codebase

80

tests authored by Bob
in Agent mode

2.86

Bobcoins used
of 40 available



Backend code review

11 findings. Race conditions, silent write failures, path traversal, missing validation. Nine implemented.



Test suite — Agent mode

Bob wrote backend/tests/test_bob_engine.py directly into the repo. 80 tests, 10 classes, all passing.



Upload security review

Five findings including magic-byte spoofing and prompt injection through a crafted filename.



Responsible AI review

Assessed against IBM's six principles. Found a seeded score being presented to a patient as an assessment.

We did not accept everything it told us



Wrong fix — caught by testing

Bob told us to restrict CORS to localhost:3000. That is the Create React App port — we use Vite on 5173. Applied verbatim, it would have blocked every request from our own frontend and broken the demo with no visible error.



Defective remediation — proven by attack

Bob found a prompt-injection vector in filenames, then proposed a regex to strip it. We implemented it exactly, then defeated it with a plain-English filename — ordinary letters have nothing to strip. We added a structural defence instead.

Four more findings were correct — and we still declined them

Add authentication

Single-user local app by design. Mitigated by loopback binding instead.

Replace the intent router

A better design, but swapping it hours before a deadline risks the demo.

Split app.py into modules

Correct advice, wrong moment. The file was already under 80 passing tests.

Move the uploads folder

Needs a misconfigured proxy that does not exist in our deployment.

You can clone it and run this yourself

```
backend/tests/test_bob_engine.py::TestFallbackIntent::test_fallback_no_appointment PASSED [ 91%]
backend/tests/test_bob_engine.py::TestEdgeCases::test_empty_prompt_string PASSED [ 92%]
backend/tests/test_bob_engine.py::TestEdgeCases::test_none_prompt PASSED [ 93%]
backend/tests/test_bob_engine.py::TestEdgeCases::test_whitespace_only_prompt PASSED [ 95%]
backend/tests/test_bob_engine.py::TestEdgeCases::test_mixed_case_prompt PASSED [ 96%]
backend/tests/test_bob_engine.py::TestEdgeCases::test_returns_string_not_none PASSED [ 97%]
backend/tests/test_bob_engine.py::TestEdgeCases::test_empty_db_does_not_crash PASSED [ 98%]
backend/tests/test_bob_engine.py::TestEdgeCases::test_data_mutation_isolation PASSED [100%]

===== 80 passed in 2.33s =====
```

The suite IBM Bob wrote in Agent mode, re-run after we changed the function it covers.

80/80

tests passing, re-run after the code they cover was changed

13

REST endpoints, each documented with real captured responses

0

console errors, 4xx or 5xx responses in a full browser pass

Also in the repository

Nine IBM Bob session transcripts with outcomes · full API documentation · architecture document with the trade-offs stated · a README that lists what the system does not do

What Health Journey does not claim



It is not encrypted at rest

The record sits in a plain file on your disk. Our privacy property is locality — it never leaves the device — not cryptography. A key stored beside the data it protects would be theatre.



It does not read your documents

Uploads are catalogued by metadata. IBM Bob can tell you a report exists; it cannot tell you what is written in it, and it says so rather than guessing.



It is not multi-user

No authentication, one person, one device, one record. Multi-user needs real auth first, and that is named as future work.



It does not give medical advice

Both engines are constrained to describing the record and deferring judgement to a clinician.

Every one of these is written in our README. We would rather a judge read it from us than discover it themselves.

Who this is for, and where it goes



The family coordinator

One person in most families tracks everyone's appointments, prescriptions and screenings. Health Journey is built for them — family profiles are a first-class feature, not an afterthought.



Anyone managing a long-term condition

Pre-diabetes, hypertension, thyroid — conditions measured in years of panels and slow trends. That is exactly the history a scattered record loses.

Roadmap

- **OCR and marker extraction**
so Bob can compare panels value by value
- **Encryption at rest**
for the record store and uploads
- **An auditable conversation log**
so a patient can retrieve what Bob said
- **Multi-user with real auth**
a household, not a single device

The next feature is the one we were honest about not having.

An AI health assistant whose most important feature is knowing when to say no.

Health Journey organises your health information.

Clinical decisions remain with qualified medical professionals.

Team NovaTra

New Horizon College of Engineering · IBM SkillsBuild SkillUp Hackathon 2026

Mantripragada Ramaa Gayatri · Allu Uma Eashanvi · Krupa L P · Madhumitha K